



Введение в Веб-Технологии

Александр Менщиков,
к.т.н., доцент ИТМО

О себе

- ИТМО
- CodeX
- Сборная по CTF
- Бэк (Go, Python, TypeScript), Фронт (React), DevOps (k8s)
- Веду курсы в ИТМО: Pentest, WebDev, OSINT, DevOps
- t.me/n0str
- menshikov@itmo.ru

План курса *

1. **Введение в Веб-Технологии:** HTML, CSS, JavaScript, Стандарты
2. **Передача данных в Веб:** HTTP, API, REST, Ajax, Cookie, Polling
3. **Хранение данных в Веб:** Local Storage, сессии, JWT
4. **Бинарные протоколы:** Websocket, DNS, HTTP2/3
5. **Веб уязвимости:** IDOR, LFI/RFI, Path Traversal, Command Injection, SSRF и SSTI
6. **Клиентские технологии безопасности:** JS, Same Origin Policy, CORS, Content Security Policy и уязвимости CSRF, XSS
7. **Прогрессивные Веб приложения:** WebDriver. Браузерные расширения. PWA. Service Workers, Web Push API и Notifications API.
8. **Протоколы аутентификации:** Protobuf, WASM, OAuth

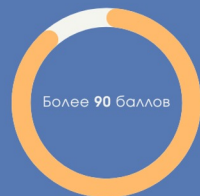
Расписание курса

- Лекции **очно** по нечетным средам с **11:30 до 13:00**
- Видеозапись лекций **не гарантируется**, слайды **будут доступны** сразу после лекции
- Практики самостоятельно, асинхронно, в удобное время на платформе LMS. На расписание практик можно не обращать внимание
- Иногда лекции могут переноситься в онлайн или быть предзаписанными. Предупрежу заранее.
- Иногда практики могут быть синхронными, вас пригласят очно или онлайн прийти. Предупредим сильно заранее.
- Иногда устраиваем синхронные вебинары Q&A по желанию вне расписания.

Экзамен

- Баллы вы набираете только в LMS
- За весь курс вы сможете набрать:
 - От 0 до 80 основных баллов
 - От 0 до 20 дополнительных баллов (задачи со *)
 - От 0 до 20 баллов на экзаменационной неделе
 - Итого: max. 120 баллов. Округляется до 100 :)
- Оценка выставляется в соответствии с БАРС
- Дедлайны фиксированы, модули открыты не будут как заранее, так и после окончания
- Не устраивает оценка – устный экзамен по билетам
- В остальных случаях – автомат
- Хорошо знаете предмет – есть сложные доп. задачи (подходите к преподавателю после лекций)
- Учитываем фёрст-блады

КАК ОЦЕНИВАЕТСЯ ВАША УЧЕБА

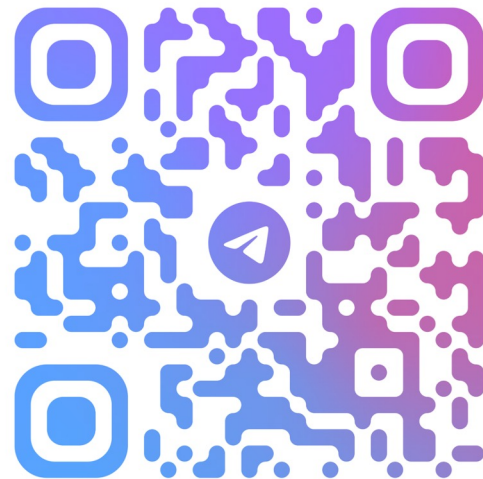


Минимум 60 баллов для зачета

Платформа для практик – LMS2.0

<https://lms.itmo.xyz/>

- ФИО на русском языке совпадающий с данными из ИСУ.
- Актуальная электронная почта
- Если забыли пароль или случайно сделали дубль аккаунта – пишите <https://t.me/n0str>
- Группа в Telegram: <https://t.me/+W0XCJ1iwwZVLZWUy>



Инвайт код: bcb93fc5-17bd-4a0c-adc4-18be6b585028

Содержание лекции

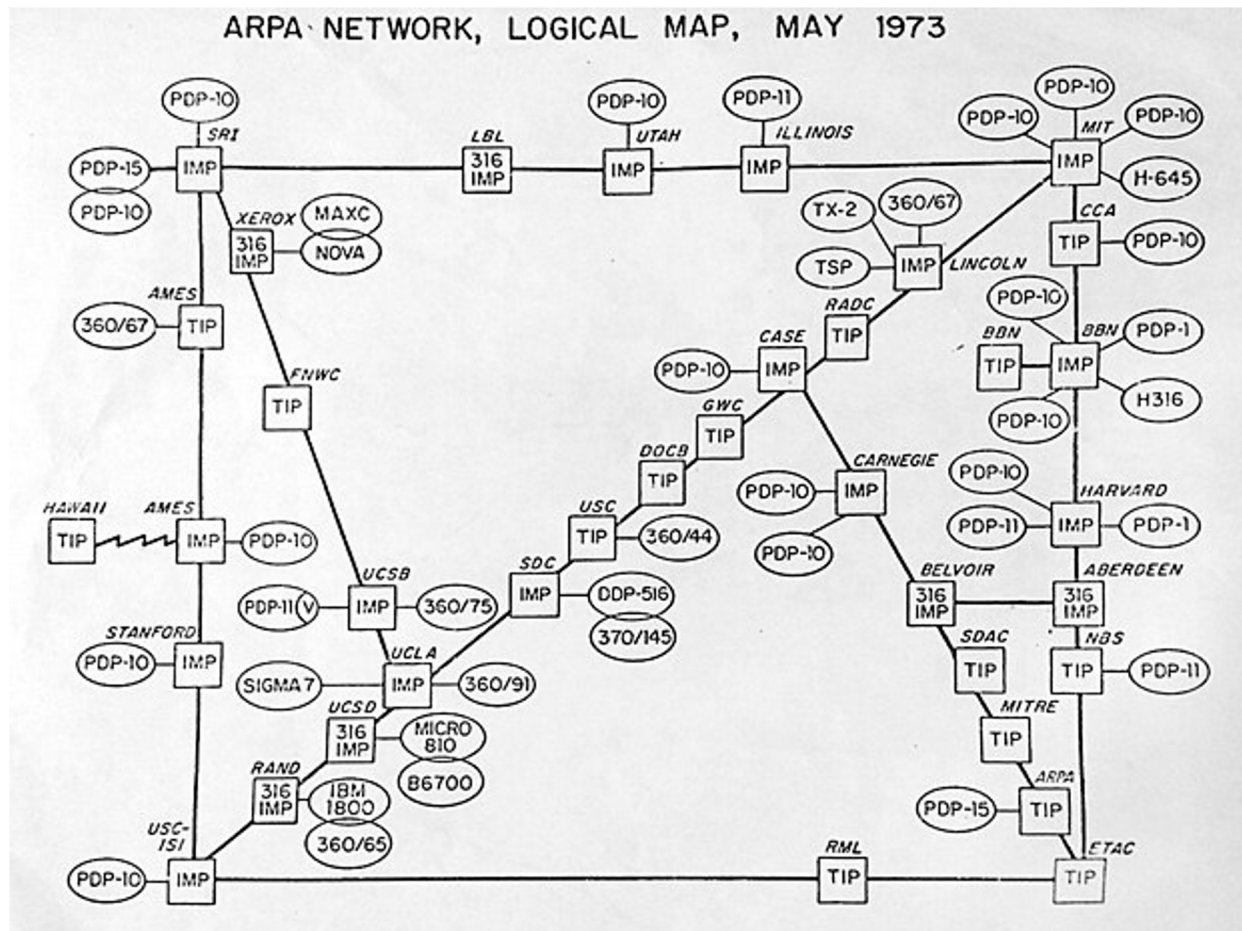
1. План курса
2. История развития Web
3. Что такое браузер?
4. HTML
5. CSS
6. JavaScript
7. Стандарты и W3C

Quiz

История Веб

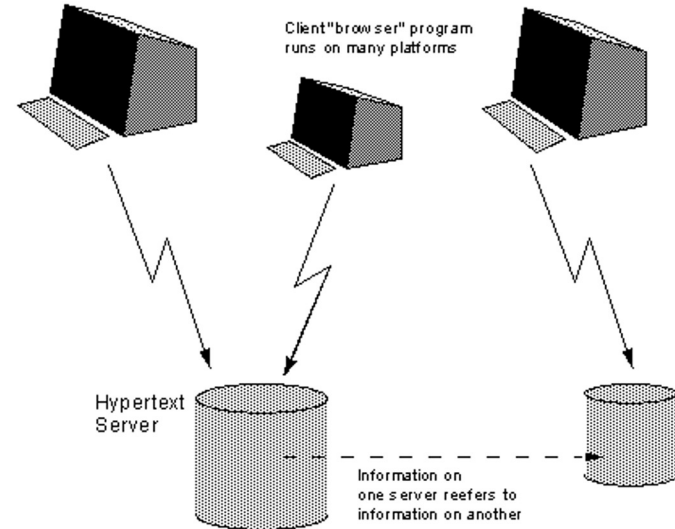
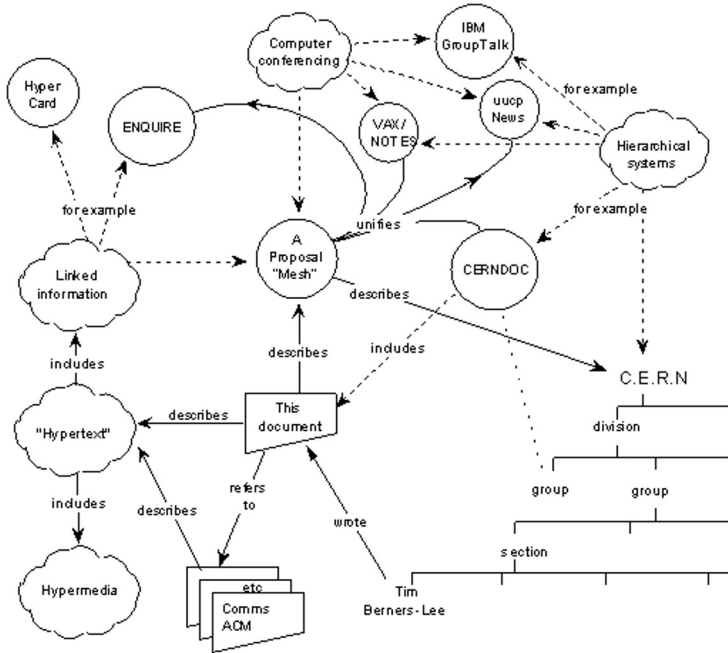
ARPA

- Основание ARPA (1958)
- Проект ARPANET (1969)
- Первое интернет-сообщение (LO)
- Связь военных, университетов и научных центров



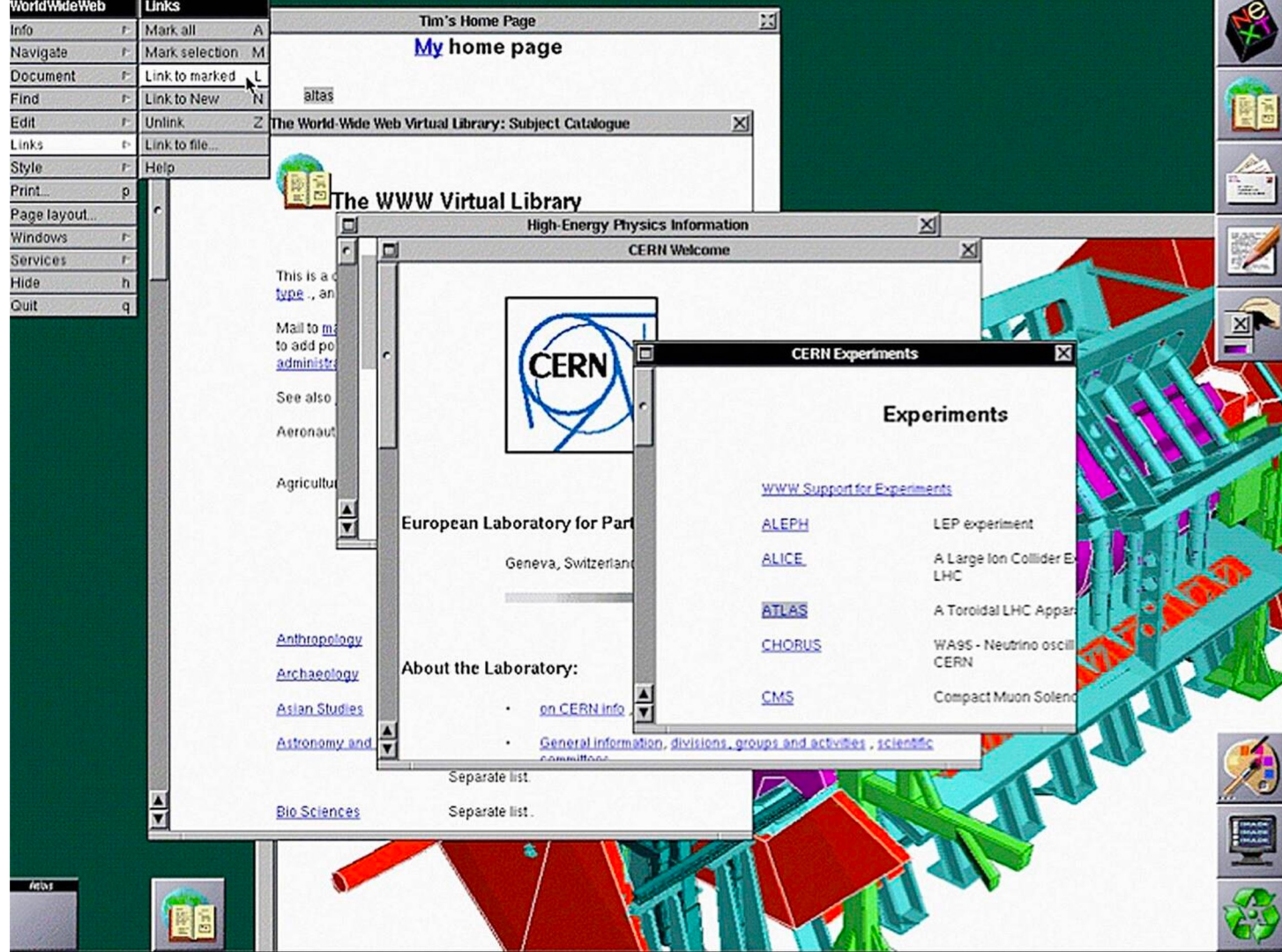
Запуск World Wide Web (WWW) в 1989

Tim Berners-Lee (CERN)



WWW

WorldWideWeb.app
Httpd server



Разработанные концепции (к 1990)

- **HTML** – HyperText Markup Language
- **URI** – Uniform Resource Identifier
- **HTTP** – Hypertext Transfer Protocol

Nicola Pellow

```
Products[11]      state. (e.g. Line Model[12] ,X11 Viola[13] ,
                  NeXTStep[14] , Servers[15] , Tools[16] , Mail
                  robot[17] , Library[18] )

Technical[19]     Details of protocols, formats, program internals
                  etc

Bibliography[20]  Paper documentation on W3 and references.

People[21]        A list of some people involved in the project.

History[22]       A summary of the history of the project.

How can I help[23] ?If you would like to support the web..

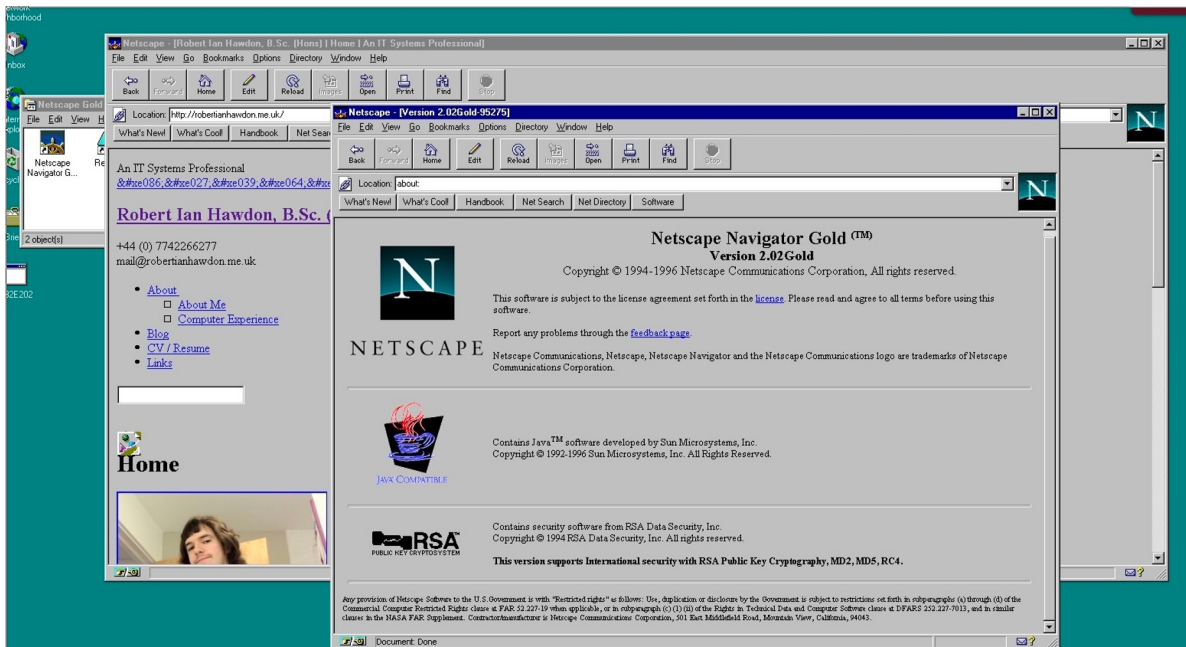
Getting code[24]  Getting the code by anonymous FTP[25] , etc.

[End]

<ref.number>, <RETURN> for more, Quit, or Help: |
```

Mosaic

1993



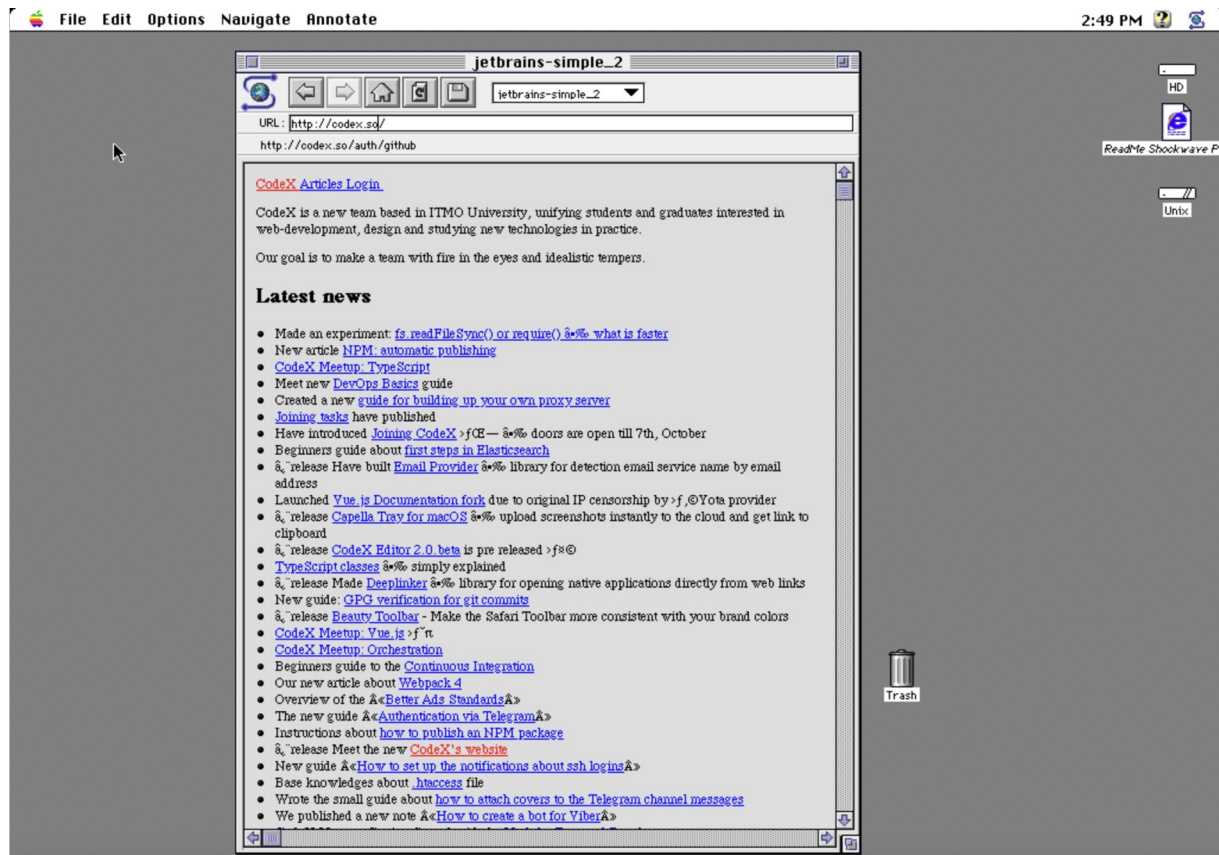
Войны браузеров

- Netscape Navigator
 - JavaScript
- Microsoft IE
 - CSS

В конце 90-х и начале 2000-х появились другие конкуренты: Opera, Safari и Google Chrome.



Demo



<https://oldweb.today/?browser=nm2-mac#19960101/http://codex.so>

Кракозябры вместо текста

к о д и р о в к а
 ea ee e4 e8 f0 ee e2 ea e0



B_	°	±	²	³	´	μ	¶	·	¸	¹	º	»	¼	½	¾	¿
C_	À	Á	Â	Ã	Ä	Å	Æ	Ç	È	É	Ê	Ë	Ì	Í	Î	Ï
D_	Ð	Ñ	Ò	Ó	Ô	Õ	Ö	×	Ø	Ù	Ú	Û	Ü	Ý	Þ	ß
E_	à	á	â	ã	ä	å	æ	ç	è	é	ê	ë	ì	í	î	ï
F_	ð	ñ	ò	ó	ô	õ	ö	÷	ø	ù	ú	û	ü	ý	þ	ÿ

CP-1252



ea ee e4 e8 f0 ee e2 ea e0
 ê î ä è ð î â ê à

Windows-1251^[15]

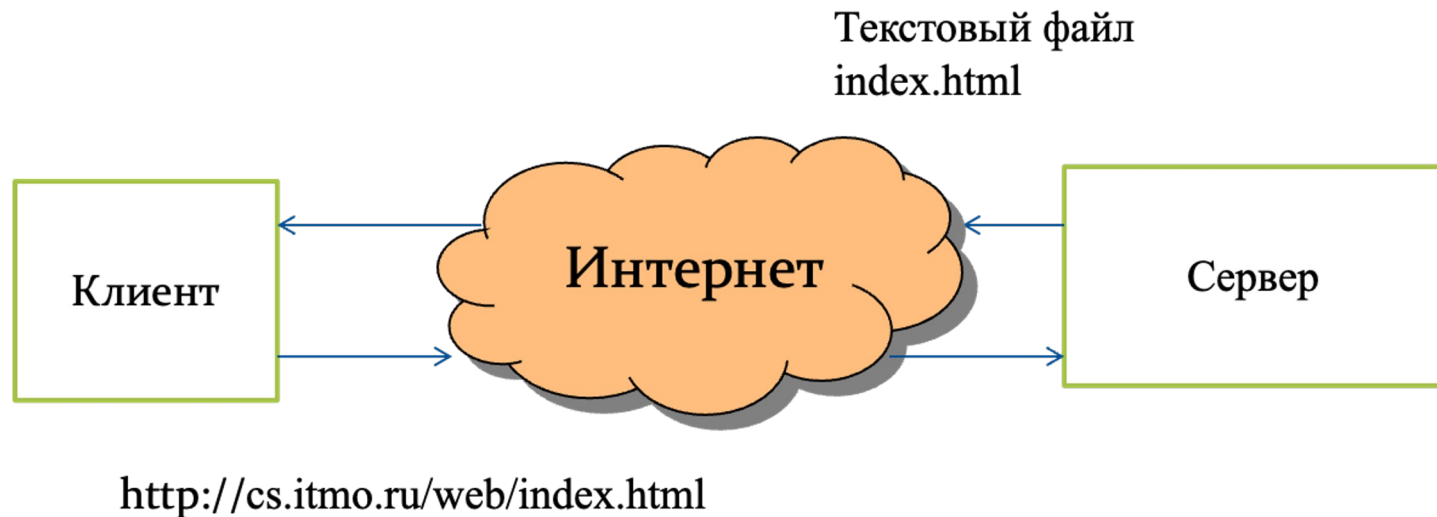
	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F
0x	NUL	SOH	STX	ETX	EOT	ENQ	ACK	BEL	BS	HT	LF	VT	FF	CR	SO	SI
1x	DLE	DC1	DC2	DC3	DC4	NAK	SYN	ETB	CAN	EM	SUB	ESC	FS	GS	RS	US
2x	SP	!	"	#	\$	%	&	'	(	)	*	+	,	-	.	/
3x	0	1	2	3	4	5	6	7	8	9	:	;	<	=	>	?
4x	@	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O
5x	P	Q	R	S	T	U	V	W	X	Y	Z	[	\	]	^	_
6x	`	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o
7x	p	q	r	s	t	u	v	w	x	y	z	{		}	~	DEL
8x	Ђ	Ѓ	Ѕ	Ї	Љ	Њ	Ћ	Ќ	Ў	Ў	Ў	Ў	Ў	Ў	Ў	Ў
9x	ђ	ѓ	ѕ	ї	љ	њ	ќ	ќ	ў	ў	ў	ў	ў	ў	ў	ў
Ax	Њ	Ў	Ў	Ў	Ў	Ў	Ў	Ў	Ў	Ў	Ў	Ў	Ў	Ў	Ў	Ў
Bx	°	±	²	³	´	μ	¶	·	¸	¹	º	»	¼	½	¾	¿
Cx	À	Á	Â	Ã	Ä	Å	Æ	Ç	È	É	Ê	Ë	Ì	Í	Î	Ï
Dx	Ð	Ñ	Ò	Ó	Ô	Õ	Ö	×	Ø	Ù	Ú	Û	Ü	Ý	Þ	ß
Ex	à	á	â	ã	ä	å	æ	ç	è	é	ê	ë	ì	í	î	ï
Fx	ð	ñ	ò	ó	ô	õ	ö	÷	ø	ù	ú	û	ü	ý	þ	ÿ

☐ Differences from Windows-1252

lâââðîäÿ êîäèðîâèâ — ýòì ìàðâ âñ,!

Что такое браузер?

Модель “клиент-сервер”



Клиент

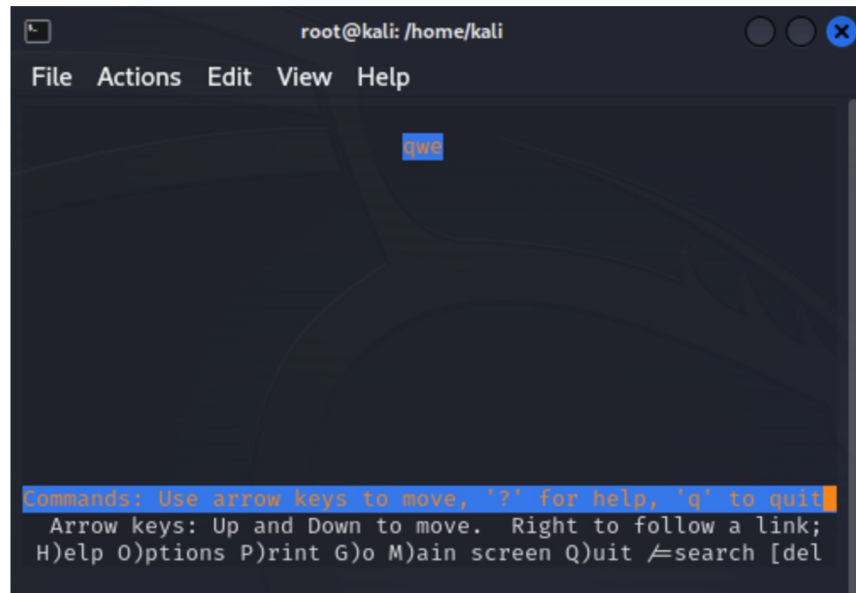
Клиент – приложение для взаимодействия с сервером.

Как клиент подключается к серверу?

- UNIX domain sockets
- Named pipe
- Shared memory
- Internet protocols

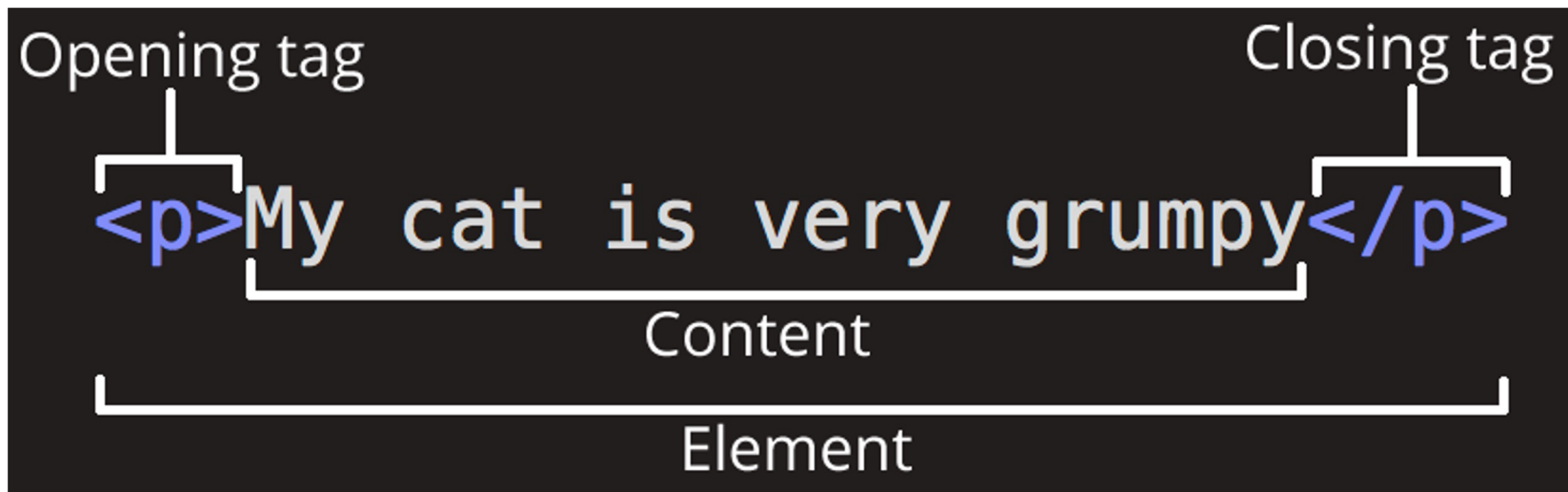
Как работает браузер?

```
1 | echo "<h1>qwe</h1>" | lynx -stdin
```



The screenshot shows a terminal window with the title bar "root@kali: /home/kali". The window contains the Lynx browser interface. At the top, there is a menu bar with "File", "Actions", "Edit", "View", and "Help". Below the menu bar, the text "qwe" is displayed in a large, bold font. At the bottom of the window, there is a status bar with the following text: "Commands: Use arrow keys to move, '?' for help, 'g' to quit". Below this, there is a list of keyboard shortcuts: "Arrow keys: Up and Down to move. Right to follow a link; H)elp O)ptions P)rint G)o M)ain screen Q)uit /search [del".

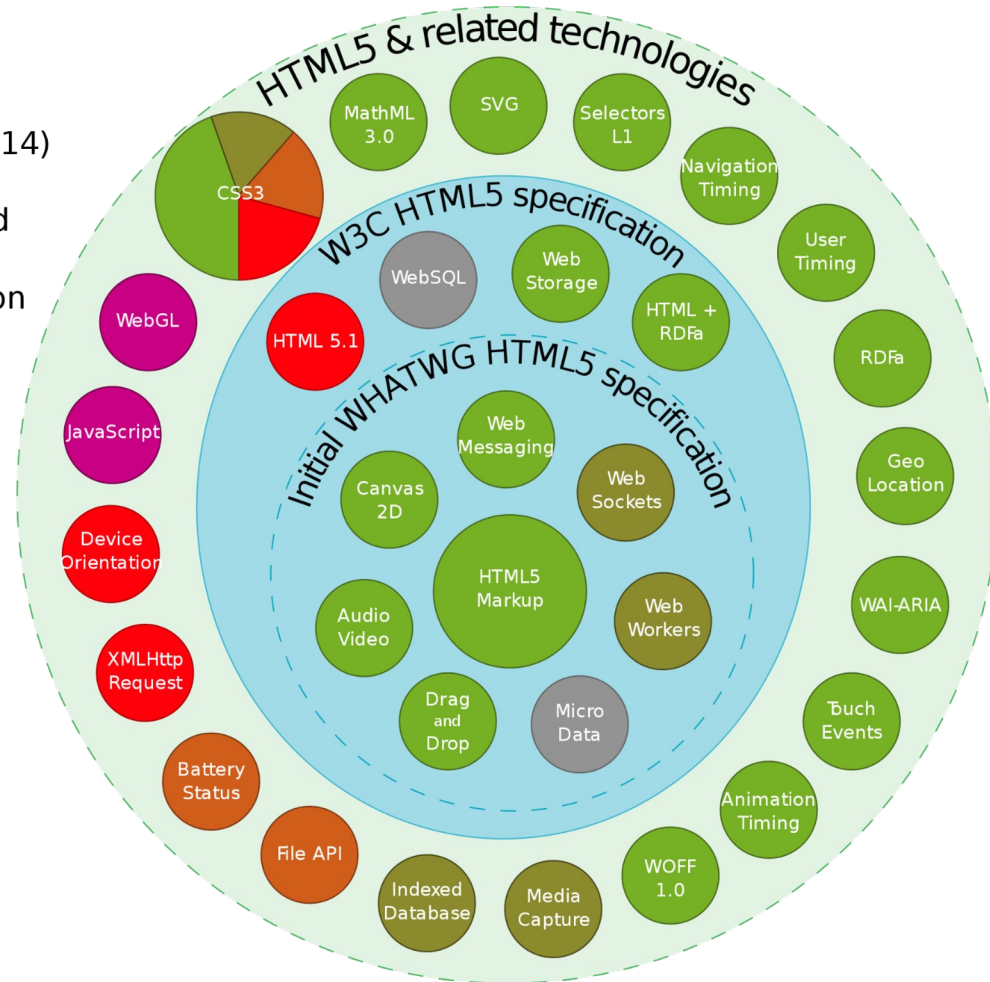
HTML



HTML5

Taxonomy & Status (October 2014)

- Recommendation/Proposed
- Candidate Recommendation
- Last Call
- Working Draft
- Non-W3C Specifications
- Deprecated or inactive



HTML Living Standard

<https://html.spec.whatwg.org/multipage/>

Термин "HTML5" широко используется для обозначения современных веб-технологий, многие из которых (хотя далеко не все) разрабатываются в WHATWG.

CSS SVG MathML ServiceWorkers

CSP
Fetch
IDB

PNG

Opus

AV1



THIS SPECIFICATION

HTTP TLS DOM Unicode WebIDL
MIME URL XML JavaScript Encoding

Синтаксис HTML

```
<!DOCTYPE html>
<html lang="en">
  <head>
    <title>Sample page</title>
  </head>
  <body>
    <h1>Sample page</h1>
    <p>This is a <a href="demo.html">simple</a> sample.</p>
    <!-- this is a comment -->
  </body>
</html>
```

Атрибуты

```
<!-- empty attributes -->
```

```
<input name=address disabled>
```

```
<input name=address disabled="">
```

```
<!-- attributes with a value -->
```

```
<input name=address maxlength=200>
```

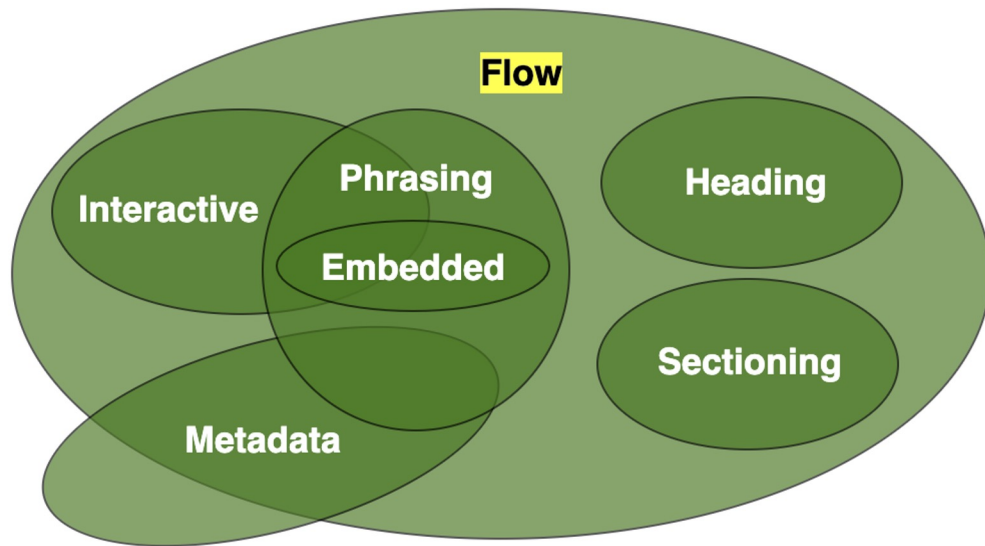
```
<input name=address maxlength='200'>
```

```
<input name=address maxlength="200">
```

Виды контента

<https://html.spec.whatwg.org/multipage/dom.html#kinds-of-content>

- Metadata content
- Flow content
- Sectioning content
- Heading content
- Phrasing content
- Embedded content
- Interactive content



Метаданные

Метаданные – это информация, которая определяет представление или поведение остального содержимого; устанавливает связь документа с другими документами; или передает иную информацию.

- [base](#)
- [command](#)
- [link](#)
- [meta](#)
- [noscript](#)
- [script](#)
- [style](#)
- [title](#)

```
<!DOCTYPE html>
<html>
  <head>
    <meta charset="utf-8">
    <title>Тег META,
атрибут charset</title>
  </head>
  <body>
    <p>Типовой
документ.</p>
  </body>
</html>
```


Потоковый контент (Flow Content)

Большинство элементов, используемых в теле документов и приложений, относятся к категории потокового контента.

⇒ `a`, `abbr`, `address`, `area` (if it is a descendant of a `map` element), `article`, `aside`, `audio`, `b`, `bdi`, `bdo`, `blockquote`, `br`, `button`, `canvas`, `cite`, `code`, `data`, `datalist`, `del`, `details`, `dfn`, `dialog`, `div`, `dl`, `em`, `embed`, `fieldset`, `figure`, `footer`, `form`, `h1`, `h2`, `h3`, `h4`, `h5`, `h6`, `header`, `hgroup`, `hr`, `i`, `iframe`, `img`, `input`, `ins`, `kbd`, `label`, `link` (if it is [allowed in the body](#)), `main` (if it is a [hierarchically correct main element](#)), `map`, `mark`, [MathML `math`](#), `menu`, `meta` (if the `itemprop` attribute is present), `meter`, `nav`, `noscript`, `object`, `ol`, `output`, `p`, `picture`, `pre`, `progress`, `q`, `ruby`, `s`, `samp`, `script`, `search`, `section`, `select`, `slot`, `small`, `span`, `strong`, `sub`, `sup`, [SVG `svg`](#), `table`, `template`, `textarea`, `time`, `u`, `u1`, `var`, `video`, `wbr`, [autonomous custom elements](#), [text](#)

Sectioning content

Sectioning content – это содержимое, определяющее область действия элементов верхнего и нижнего колонтитулов.

- `article`
- `aside`
- `nav`
- `section`

```
<article>
  <hgroup>
    <h2>Apples</h2>
    <p>Tasty, delicious fruit!</p>
  </hgroup>
  <p>The apple is the pomaceous fruit of the apple tree.</p>
  <section>
    <h3>Red Delicious</h3>
    <p>These bright red apples are the most common found in many
      supermarkets.</p>
  </section>
  <section>
    <h3>Granny Smith</h3>
    <p>These juicy, green apples make a great filling for
      apple pies.</p>
  </section></article>
```

Heading content

Heading content определяет заголовок раздела (как явно обозначенный с помощью элементов содержания раздела, так и подразумеваемый самим содержанием заголовка).

- `h1`
- `h2`
- `h3`
- `h4`
- `h5`
- `h6`
- `hgroup`

```
<hgroup>  
  <h1>The reality dysfunction</h1>  
  <p>Space is not the only  
void</p>  
</hgroup>
```

Phrasing content

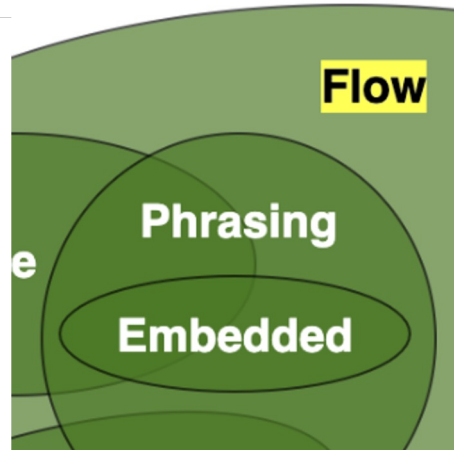
Фразовый контент – это текст документа, а также элементы, которые маркируют этот текст на внутриабзацном уровне. Фразовый контент образует абзацы.

Phrasing content is the text of the document, as well as elements that mark up that text at the intra-paragraph level. Runs of [phrasing content](#) form [paragraphs](#).

⇒ [a](#), [abbr](#), [area](#) (if it is a descendant of a [map](#) element), [audio](#), [b](#), [bdi](#), [bdo](#), [br](#), [button](#), [canvas](#), [cite](#), [code](#), [data](#), [datalist](#), [del](#), [dfn](#), [em](#), [embed](#), [i](#), [iframe](#), [img](#), [input](#), [ins](#), [kbd](#), [label](#), [link](#) (if it is [allowed in the body](#)), [map](#), [mark](#), [MathML math](#), [meta](#) (if the [itemprop](#) attribute is present), [meter](#), [noscript](#), [object](#), [output](#), [picture](#), [progress](#), [q](#), [ruby](#), [s](#), [samp](#), [script](#), [select](#), [slot](#), [small](#), [span](#), [strong](#), [sub](#), [sup](#), [SVG svg](#), [template](#), [textarea](#), [time](#), [u](#), [var](#), [video](#), [wbr](#), [autonomous custom elements](#), [text](#)

HTML Demo: `<kbd>` RESET

HTML	CSS	OUTPUT
<pre>1 <p>Please press <kbd>Ctrl</kbd> + 2 <kbd>Shift</kbd> + <kbd>R</kbd> to re-render an MDN page.</p></pre>		Please press <code>Ctrl</code> + <code>Shift</code> + <code>R</code> to re-render an MDN page.



Embedded content

Встроенный контент – это контент, который импортирует в документ другой ресурс, или контент из другого словаря, который вставляется в документ.

- `audio`
- `canvas`
- `embed`
- `iframe`
- `img`
- [MathML math](#)
- `object`
- `picture`
- [SVG svg](#)
- `video`

```
<p>
  real number
  <math display="inline">
    <mfrac>
      <msup>
        <mi>π</mi>
        <mn>2</mn>
      </msup>
      <mn>6</mn>
    </mfrac></math>
  >.
</p>
```

real number $\frac{\pi^2}{6}$.

Интерактивный контент

Интерактивный контент – это контент, специально предназначенный для взаимодействия с пользователем.

Демо

HTML Demo: <video>

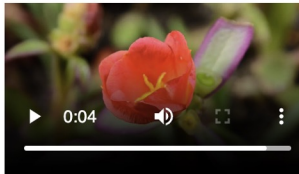
RESET

HTML

CSS

```
1 <video controls width="250">
2   <source src="/media/cc0-
3     videos/flower.webm" type="video/webm" />
4   <source src="/media/cc0-
5     videos/flower.mp4" type="video/mp4" />
6   Download the
7   <a href="/media/cc0-
8     videos/flower.webm">WEBM</a>
9   or
10  <a href="/media/cc0-
11    videos/flower.mp4">MP4</a>
12  </video>
```

OUTPUT



⇒ **a** (if the **href** attribute is present), **audio** (if the **controls** attribute is present), **button**, **details**, **embed**, **iframe**, **img** (if the **usemap** attribute is present), **input** (if the **type** attribute is *not* in the **Hidden** state), **label**, **select**, **textarea**, **video** (if the **controls** attribute is present)

<https://hcdev.ru/html/video/>

<https://developer.mozilla.org/ru/docs/Web/HTML/Element/video>

CSS

<https://developer.mozilla.org/en-US/docs/Web/CSS>

<https://www.w3.org/Style/CSS/#specs>

Каскадные таблицы стилей (CSS) – это язык для описания представления HTML документа. CSS описывает, как элементы должны отображаться на экране.

- Программные (js)
- Внутренние (inline)
- Глобальные (style tag)
- Связанные (stylesheet file)

Пример CSS стилей

```
<style>
body {
  background-color: lightblue;
}
```

```
h1 {
  color: white;
  text-align: center;
}
```

```
p {
  font-family: verdana;
  font-size: 20px;
}
```

```
</style>
</head>
<body>
```

```
<h1>My First CSS Example</h1>
<p>This is a paragraph.</p>
```



селектор	свойство	значение
body	{ background:	#ffc910; }

Специфичность

*	{}	/*	a=0	b=0	c=0	->	специфичность	=	0	*/
li	{}	/*	a=0	b=0	c=1	->	специфичность	=	1	*/
li:first-line	{}	/*	a=0	b=0	c=2	->	специфичность	=	2	*/
ul li	{}	/*	a=0	b=0	c=2	->	специфичность	=	2	*/
ul ol+li	{}	/*	a=0	b=0	c=3	->	специфичность	=	3	*/
ul li.red	{}	/*	a=0	b=1	c=2	->	специфичность	=	12	*/
li.red.level	{}	/*	a=0	b=2	c=1	->	специфичность	=	21	*/
#t34	{}	/*	a=1	b=0	c=0	->	специфичность	=	100	*/
#content #wrap	{}	/*	a=2	b=0	c=0	->	специфичность	=	200	*/

Если два селектора имеют одинаковую специфичность, то применяться будет тот стиль, что указан в коде ниже.

DevTools

ИТМО



Версия для слабовидящих

Старая
версия
сайта



English



中文版



Español



НОВОСТИ



МЕНЮ

The screenshot displays the Chrome DevTools interface. The **Elements** panel on the left shows the DOM tree with the following structure:

```
<!DOCTYPE html>
<html lang="ru">
  <head>
  </head>
  <body style=...
    <div id="__next">
      <div class="Navigation_navigation_SNPJA">
      </div>
      <main class="PageLayout_layout_wrapper_i45b6">
        <div class style="width: calc(-272.16px + 100vw);">
          <section>
          </section>
          <section class="Section_section_2Pzmc Stats_stats_MtEjk">
          </section>
          <section class="Section_section_2Pzmc">
          </section>
          <section class="Section_section_2Pzmc">
          </section>
          <section class="Section_section_2Pzmc">
          </section>
          <section class="Section_section_2Pzmc">
          </section>
          <div class="SocialNetwork_container_Kpg54">
          </div>
          <footer class="Footer_footer_8ba8j">
          </footer>
        </div>
      </main>
    </div>
    <script id="__NEXT_DATA__" type="application/json">
    </script>
    <next-route-announcer>
    </next-route-announcer>
    <script src="/_next/static/chunks/pages/news-a0c7a322474bedfb.js">
    </script>
    <script src="/_next/static/chunks/pages/menu-e5ba79be15f1afb3.js">
    </script>
  </body>
</html>
```

The **Styles** panel on the right shows the computed styles for the selected element:

```
element.style {
}
* {
  margin: 0;
}
*, :after, :before {
  box-sizing: border-box;
}
section {
  display: block;
}
Inherited from body
body {
  font-size: 12px;
  line-height: 1.5;
  color: #1d1d1d;
  font-synthesis: none;
  overflow-x: hidden;
  text-rendering: optimizelegibility;
  -webkit-font-smoothing: antialiased;
  -moz-osx-font-smoothing: grayscale;
  overscroll-behavior: none;
}
```

JavaScript

```
<script>alert ()</script>
```

```
<button onclick="document.write('Hello, world!')">Click me</button>
```

```
<script type="text/javascript" src="path-to-javascriptfile.js"></script>
```

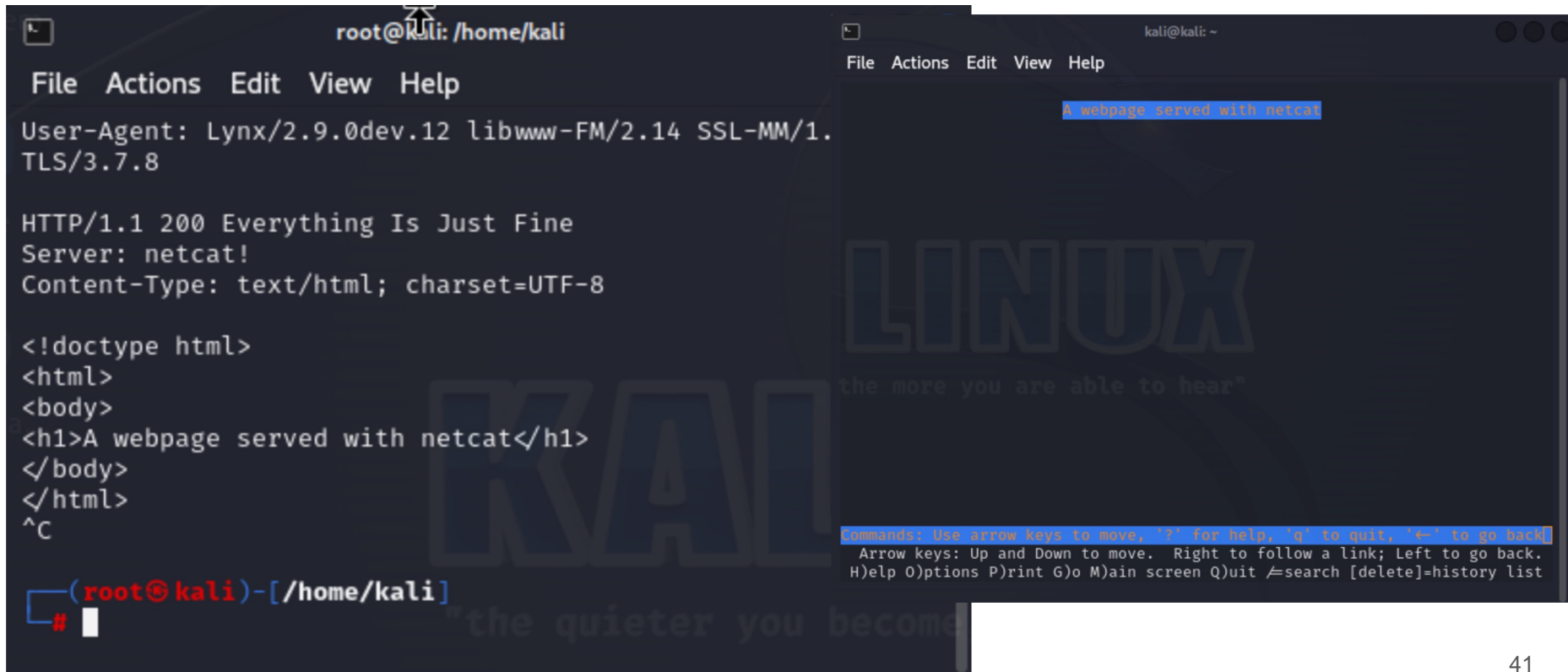
<https://www.learn-js.org/>

<https://learn.javascript.ru/>

Чего НЕ может JavaScript?

- Читать/записывать произвольные файлы на жёстком диске
- Взаимодействовать с ОС (API)
- Различные окна/вкладки не знают друг о друге (Same Origin Policy)
- Получать данные с других сайтов/доменов (CORS, CSP)

HTTP



```
root@kali: /home/kali
File Actions Edit View Help
User-Agent: Lynx/2.9.0dev.12 libwww-FM/2.14 SSL-MM/1.
TLS/3.7.8

HTTP/1.1 200 Everything Is Just Fine
Server: netcat!
Content-Type: text/html; charset=UTF-8

<!doctype html>
<html>
<body>
<h1>A webpage served with netcat</h1>
</body>
</html>
^C

(root@kali)-[/home/kali]
#
```

```
kali@kali: ~
File Actions Edit View Help
A webpage served with netcat

LINUX
the more you are able to hear"

Commands: Use arrow keys to move, '?' for help, 'q' to quit, '←' to go back
Arrow keys: Up and Down to move. Right to follow a link; Left to go back.
H)elp O)ptions P)rint G)o M)ain screen Q)uit /search [delete]=history list
```

- ▶ Frame 22: 66 bytes on wire (528 bits), 66 bytes captured (528 bits) on interface lo, id 0
- ▶ Ethernet II, Src: Xerox_00:00:00 (00:00:00:00:00:00), Dst: Xerox_00:00:00 (00:00:00:00:00:00)
- ▶ Internet Protocol Version 4, Src: 127.0.0.1, Dst: 127.0.0.1
- ▶ Transmission Control Protocol, Src Port: 3000, Dst Port: 60356, Seq: 188, Ack: 237, Len: 0
- ▶ [8 Reassembled TCP Segments (187 bytes): #8(36), #10(2), #12(15), #14(2), #16(123), #18(7), #20(2), #22(0)]
- ▶ Hypertext Transfer Protocol
- ▶ Line-based text data: text/html (6 lines)

```

0000  48 54 54 50 2f 31 2e 31 20 32 30 30 20 45 76 65  HTTP/1.1 200 Eve
0010  72 79 74 68 69 6e 67 20 49 73 20 4a 75 73 74 20  rything Is Just
0020  46 69 6e 65 0d 0a 53 65 72 76 65 72 3a 20 6e 65  Fine..Se rver: ne
0030  74 63 61 74 21 0d 0a 43 6f 6e 74 65 6e 74 2d 54  tcat!..C ontent-T
0040  79 70 65 3a 20 74 65 78 74 2f 68 74 6d 6c 3b 20  ype: tex t/html;
0050  63 68 61 72 73 65 74 3d 55 54 46 2d 38 0d 0a 0d  charset= UTF-8...
0060  0a 3c 21 64 6f 63 74 79 70 65 20 68 74 6d 6c 3e  .<!docty pe html>
0070  0d 0a 3c 68 74 6d 6c 3e 0d 0a 3c 62 6f 64 79 3e  ..<html> ..<body>
0080  0d 0a 3c 68 31 3e 41 20 77 65 62 70 61 67 65 20  ..<h1>A  webpage
0090  73 65 72 76 65 64 20 77 69 74 68 20 6e 65 74 63  served w ith netc
00a0  61 74 3c 2f 68 31 3e 0d 0a 3c 2f 62 6f 64 79 3e  at</h1>.. </body>
00b0  0d 0a 3c 2f 68 74 6d 6c 3e 0d 0a 3c 2f 62 6f 64 79 3e  ..</html >..

```

Frame (66 bytes)

Reassembled TCP (187 bytes)

Hypertext Transfer Protocol (http), 97 byte(s)

✓ Show packet bytes

× Close

Help

HTTP запрос

curl http://wad.itmo.xyz -vvv

Метод

```
* Trying 185.199.108.153...
* TCP_NODELAY set
* Connected to wad.itmo.xyz (185.199.108.153) port 80 (#0)
> GET / HTTP/1.1
> Host: wad.itmo.xyz
> User-Agent: curl/7.64.1
> Accept: */*
>
```

```
97 db 47 45 54 20 2f 20 48 54 54 50 2f 31 2e 31
0d 0a 48 6f 73 74 3a 20 77 61 64 2e 69 74 6d 6f
2e 78 79 7a 0d 0a 55 73 65 72 2d 41 67 65 6e 74
3a 20 63 75 72 6c 2f 37 2e 36 34 2e 31 0d 0a 41
63 63 65 70 74 3a 20 2a 2f 2a 0d 0a 0d 0a
```

```
..GET / HTTP/1.1
..Host: wad.itmo
.xyz..User-Agent
: curl/7.64.1..A
ccept: */*....
```

HTTP ответ

```
curl http://wad.itmo.xyz -vvv
```

Статус

```
< HTTP/1.1 301 Moved Permanently
< Server: GitHub.com
< Content-Type: text/html
< Location: https://wad.itmo.xyz/
< Content-Length: 162
< Date: Thu, 02 Apr 2020 11:30:02 GMT
<
<html>
<head><title>301 Moved Permanently</title></head>
<body>
<center><h1>301 Moved Permanently</h1></center>
<hr><center>nginx</center>
</body>
</html>
* Connection #0 to host wad.itmo.xyz left intact
* Closing connection 0
```


Как браузер рендерит веб-страницу?

1. Резолвинг DNS

После того, как пользователь введет URL-адрес, браузер узнает, к какому серверу ему нужно подключиться.

```
> dig webtech.itmo.xyz
```

2. HTTP запрос

После того, как мы узнали IP адрес – можно подключиться к нему по протоколу HTTP (обычный текст поверх TCP сокета).

```
GET / HTTP/1.0
Host: webtech.itmo.xyz
Accept: text/html, text/plain, text/sgml, text/css, */*;q=0.01
Accept-Encoding: gzip, compress, bzip2
Accept-Language: en
User-Agent: Lynx/2.9.0dev.12 libwww-FM/2.14 SSL-MM/1.4.1
GNUTLS/3.7.8
```

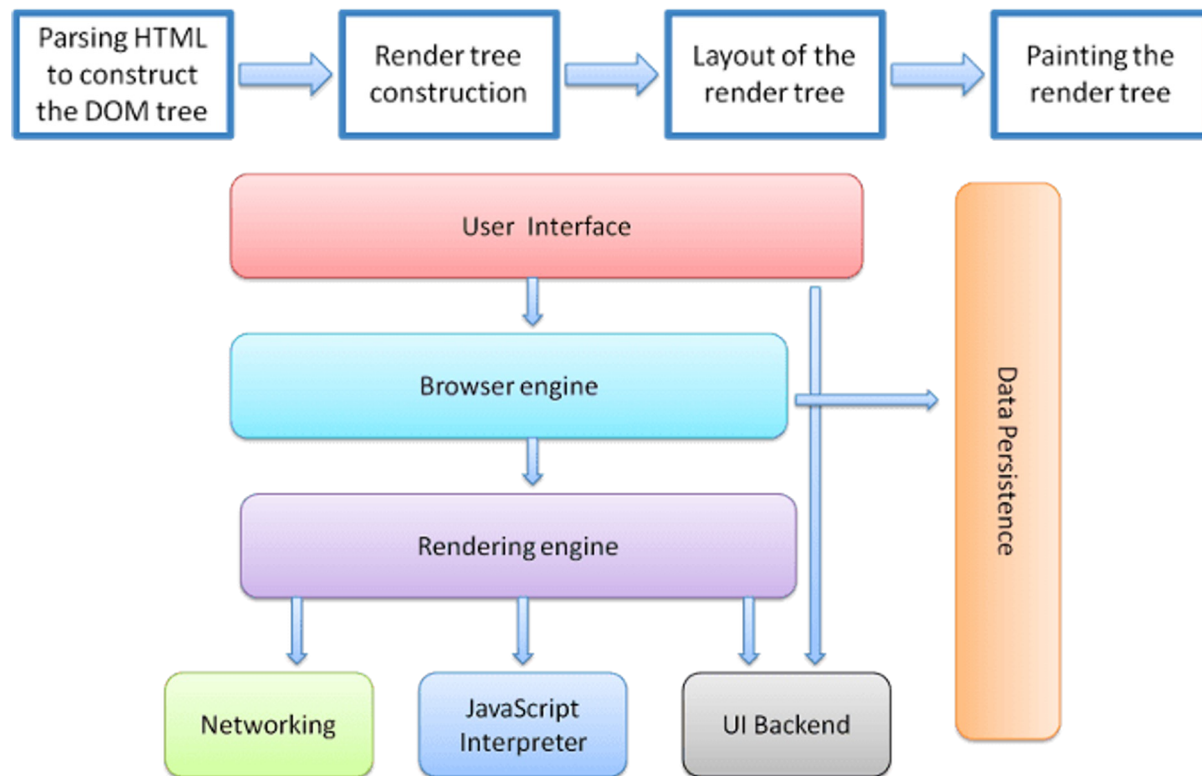
3. Получаем HTTP ответ

В результате клиент-серверного взаимодействия к нам по TCP приходит обычный текст ответа (HTTP протокол).

```
HTTP/1.1 200 Everything Is Just Fine
Server: netcat!
Content-Type: text/html; charset=UTF-8
```

```
<!doctype html>
<html>
<body>
<h1>A webpage served with netcat</h1>
</body>
</html>
```

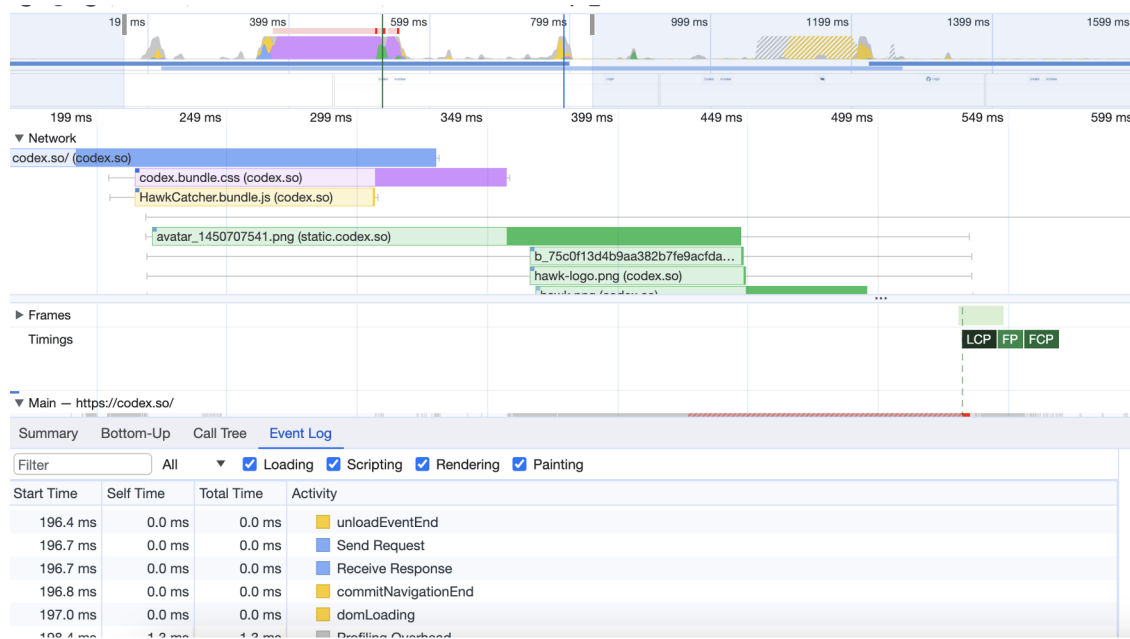
4. Первичный парсинг HTML



5. Пост-загрузка

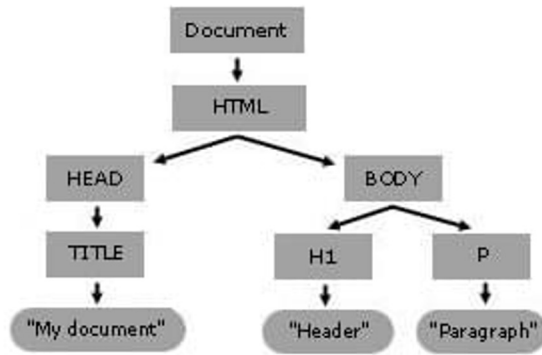
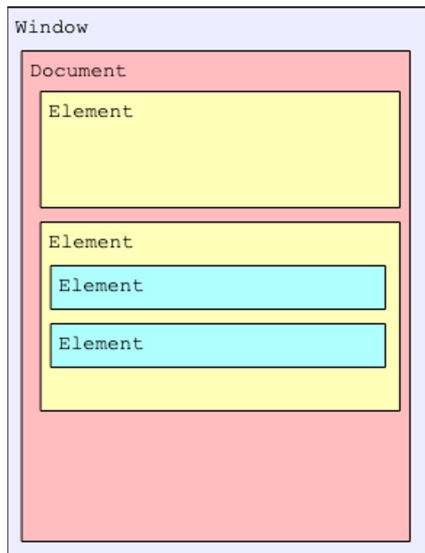
Выполнение всех остальных действий:

- Скрипты JavaScript
- Загрузка CSS, картинок и прочей статики
- Триггеры пользователем



Document Object Model (DOM)

Объектная модель документа (DOM) — это программный интерфейс для веб-документов. Он представляет страницу со всей структурой, стилями и содержанием. DOM представляет документ в виде узлов и объектов.



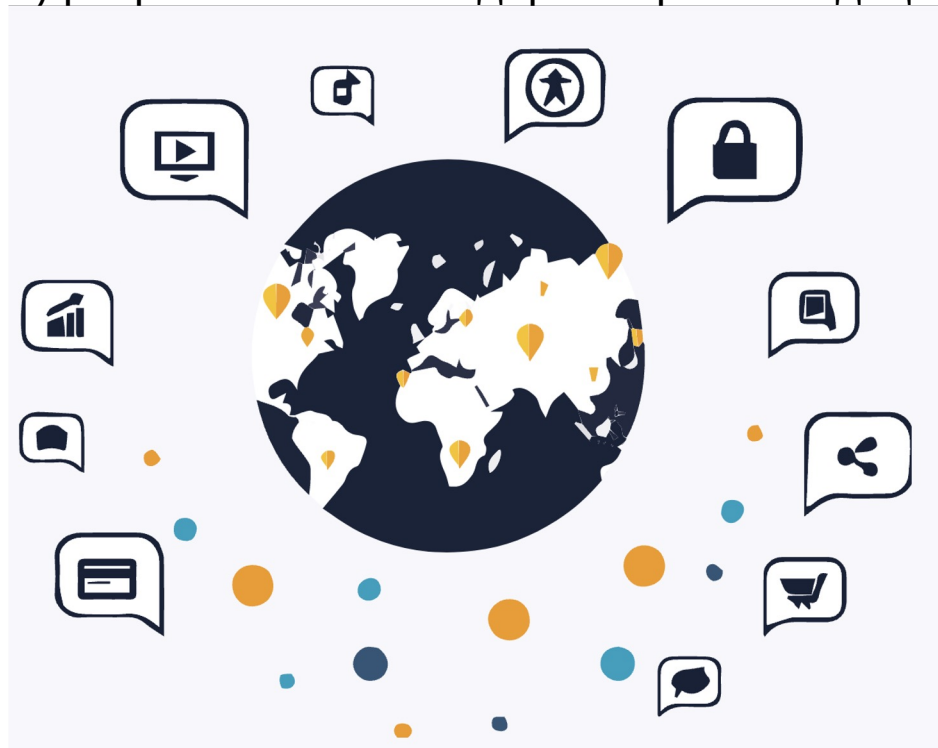
```
<!DOCTYPE html>
<html>
  <head> ... </head>
  <body>
    <header class="site-header"> ... </header>
    <div class="index-page">
      <div class="center_side"> == $0
        <div class="codex-logo"></div>
        <p> ... </p>
        <p>Our goal is to make a team with fire in the eyes and .
        <section class="site-section"> ... </section>
        <section class="site-section"> ... </section>
        <section class="site-section"> ... </section>
        <section class="site-section follow-block"> ... </section>
        <section class="site-section thanks-block"> ... </section>
      </div>
    </div>
```

Стандарты и W3C

World Wide Web Consortium

Консорциум Всемирной паутины (W3C) разрабатывает стандарты и рекомендации по Веб.

<https://www.w3.org/standards/>



Request for Comments (RFC)

Рабочее предложение — документ из серии пронумерованных информационных документов Интернета, содержащих технические спецификации и стандарты, широко применяемые во всемирной сети. Название «Request for Comments» ещё можно перевести как «заявка (запрос) на отзывы» или «тема для обсуждения».

В настоящее время первичной публикацией документов RFC занимается **IETF** под эгидой открытой организации “Общество Интернета” (ISOC). Правами на RFC обладает именно Общество Интернета.

RFC1945 – Hypertext Transfer Protocol -- HTTP/1.0

<https://www.ietf.org/rfc/rfc1945.txt>

Full-Request and Full-Response use the generic message format of RFC 822 [7] for transferring entities. Both messages may include optional header fields (also known as "headers") and an entity body. The entity body is separated from the headers by a null line (i.e., a line with nothing preceding the CRLF).

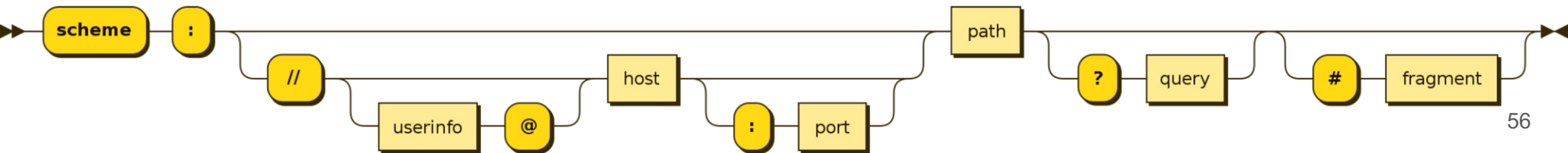
```
Full-Request    = Request-Line           ; Section 5.1
                  *( General-Header       ; Section 4.3
                    | Request-Header      ; Section 5.2
                    | Entity-Header )     ; Section 7.1
                  CRLF
                  [ Entity-Body ]        ; Section 7.2

Full-Response   = Status-Line            ; Section 6.1
                  *( General-Header       ; Section 4.3
                    | Response-Header     ; Section 6.2
```

Uniform Resource Identifier (URI)

Единый идентификатор ресурса (URI) — это уникальная последовательность символов, которая идентифицирует логический или физический ресурс, используемый в Веб. URI могут использоваться для идентификации чего угодно, включая объекты реального мира (люди, места, концепции) или информационные ресурсы (веб-страницы, книги).

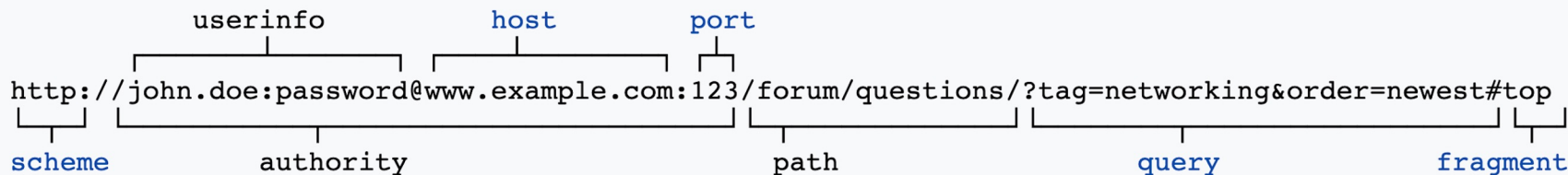
<https://datatracker.ietf.org/doc/html/rfc1738> Uniform Resource Locators (URL)



URL

Единый указатель ресурса (URL) — это URI, который определяет средства воздействия на ресурс или получения его представления, т. е. указывает как его основной механизм доступа, так и сетевое расположение.

Например, URL-адрес **http://example.org/wiki/Main_Page** относится к ресурсу, определенному как **/wiki/Main_Page**, представление которого можно получить через протокол передачи гипертекста (**http:**) от сетевого узла, доменное имя которого example.org <https://datatracker.ietf.org/doc/html/rfc1738#section-4>



Uniform Resource Name (URN)

URN — это URI, который идентифицирует ресурс по имени в определенном пространстве имен. URN может использоваться для описания ресурса, не подразумевая его местонахождение или способ доступа к нему.

Например, в системе Международного стандартного номера книги (ISBN) ISBN **0-486-27557-4** идентифицирует конкретное издание пьесы Шекспира «Ромео и Джульетта». URN для этого издания будет **urn:isbn:0-486-27557-4**. Однако он не дает никакой информации о том, где найти копию этой книги.

Can I Use?

<https://caniuse.com/>

CSS Grid Layout (level 1) 📄 - CR



Baseline Widely available across major browsers



Chrome	Edge *	Safari	Firefox	Opera	IE	Chrome for Android	Safari on iOS *	Samsung Internet	Opera Mini *	Opera Mobile *	UC Browser for Android	Android Browser *	Firefox for Android	QQ Browser	Baidu Browser	KaiOS Browser
4-28			2-39													
1 29-56			3 40-51	10-27												
4 57	2 12-15	3.1-10	4 52-53	1 28-43	6-9		3.2-10.2	4-5.4								
58-120	16-120	10.1-17.2	54-121	44-105	2 10		10.3-17.2	6.2-22		12-12.1		2.1-4.4.4				2.5
121	121	17.3	122	106	2 11	121	17.3	23	all	73	15.5	121	122	13.1	13.18	3.1
122-124		17.4-TP	123-125													

Уязвимости веб?

Frame, iframe

Name	Status
 iframe.html	200
 www.w3schools.com	(blocked:other)
 codex.so	200

<https://developer.mozilla.org/en-US/docs/Web/HTML/Element/iframe>

https://www.w3schools.com/tags/tryit.asp?filename=tryhtml_iframe

HTML

CSS

```
1 <iframe
2   id="inlineFrameExample"
3   title="Inline Frame Example"
4   width="300"
5   height="200"
6
7   src="https://www.openstreetmap.org/export/embed.
8     html?
      bbox=-0.004017949104309083%2C51.47612752641776%2
      C0.00030577182769775396%2C51.478569861898606&lay
      er=mapnik">
9 </iframe>
```

OUTPUT



Clickjacking

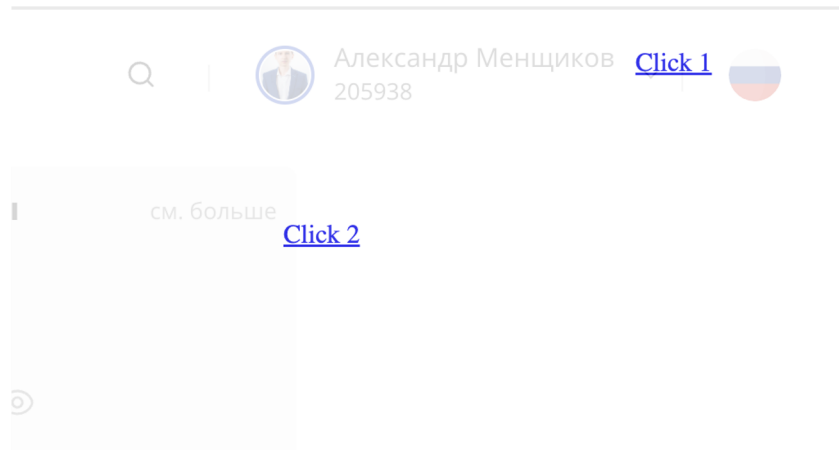
Атака типа clickjacking (англ. «захват клика») позволяет вредоносной странице кликнуть по сайту-жертве от имени посетителя.

1. Посетителя заманивают на вредоносную страницу
2. На странице есть ссылка/кнопка, которая не выглядит подозрительно
3. Поверх этой ссылки вредоносная страница размещает прозрачный `<iframe>` с `src` на целевой сайт таким образом, что кнопка целевого сайта находится прямо над этой ссылкой
4. При попытке клика на эту ссылку посетитель на самом деле нажимает на кнопку внутри фрейма

Clickjacking Demo

Clickjacking

```
<style>
  iframe {
    width: 400px;
    height: 100px;
    position: absolute;
    top: 5px;
    left: -14px;
    opacity: 0.3;
    z-index: 1;
  }
</style>
<iframe src="bank.html"></iframe>
<button>Нажмите сюда!</button>
```



Нажми, чтобы разбогатеть:

Нажмите сюда!

...

<https://clickjacking.webtech.itmo.xyz/>

Защита от Clickjacking

HTTP заголовок X-Frame-Options

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options>

Syntax

There are two possible directives for `X-Frame-Options`:

HTTP



```
X-Frame-Options: DENY
```

```
X-Frame-Options: SAMEORIGIN
```

Полезные ссылки

- История
 - <https://www.icann.org/ru/blogs/details/the-first-message-transmission-29-10-2019-ru>
- Архитектура
 - https://neerc.ifmo.ru/wiki/index.php?title=%D0%9F%D1%80%D0%B5%D0%B4%D1%81%D1%82%D0%B0%D0%B2%D0%BB%D0%B5%D0%BD%D0%B8%D0%B5_%D1%81%D0%B8%D0%BC%D0%B2%D0%BE%D0%BB%D0%BE%D0%B2_%D1%82%D0%B0%D0%B1%D0%BB%D0%B8%D1%86%D1%8B_%D0%BA%D0%BE%D0%B4%D0%B8%D1%80%D0%BE%D0%B2%D0%BE%D0%BA
 - <https://gchq.github.io/CyberChef>
- CSS
 - <https://html5css.ru/css/default.php>
 - <https://htmlbook.ru/samcss>
- JavaScript
 - <https://learn.javascript.ru/>
 - <https://www.learn-js.org/>

Вопросы?